

회의명: 관리자 권한 관리 기능 개선 회의

일시: 2026년 6월 13일 금요일 14:00~15:10

장소: 온라인 회의

참석자: 서비스기획팀 이수진, 백엔드팀 박도현, 프론트엔드팀 최유리, 보안담당 김태훈,
QA 담당 정민아

1. 회의 목적

현재 관리자 페이지의 권한 관리 기능은 관리자 계정을 생성한 뒤 역할을 선택하는 방식으로만 동작한다. 운영팀에서 세부 메뉴별 접근 권한을 다르게 설정하고 싶다는 요청이 있었고, 최근 외주 운영 인력이 일부 기능에 접근하지 못하도록 제한해야 한다는 요구도 추가되었다. 이번 회의에서는 1차 개선 범위를 확정하고, 보안상 반드시 필요한 통제 항목을 정리한다.

2. 논의 내용

현재 관리자 권한은 **SUPER_ADMIN**, **MANAGER**, **VIEWER** 세 가지 역할로만 구분되어 있다. **SUPER_ADMIN**은 모든 메뉴 접근이 가능하고, **MANAGER**는 대부분의 운영 메뉴에 접근할 수 있으며, **VIEWER**는 조회 기능만 사용할 수 있다. 그러나 실제 운영에서는 주문 관리만 가능한 관리자, 환불 승인만 가능한 관리자, 통계 조회만 가능한 관리자처럼 더 세분화된 권한이 필요하다.

백엔드팀은 메뉴별 권한 테이블을 새로 만들면 가장 유연하지만, 이번 주 안에 적용하기에는 범위가 크다고 설명했다. 특히 기존 관리자 **API**마다 권한 체크 방식이 다르기 때문에, 모든 **API**를 한 번에 수정하면 회귀 오류 가능성이 높다. 따라서 이번 1차 개선에서는 역할을 새로 늘리기보다, 기존 **MANAGER** 역할 안에서 환불 승인 기능만 별도 권한으로 분리하는 방안을 제안했다.

프론트엔드팀은 권한이 없는 메뉴를 아예 숨길지, 비활성화 상태로 보여줄지 결정해야 한다고 말했다. 보안담당자는 단순히 프론트에서 메뉴를 숨기는 것만으로는 충분하지 않고, 반드시 백엔드 **API**에서도 권한을 검증해야 한다고 강조했다. 따라서 화면에서는 권한이 없는 메뉴를 숨기되, **API** 호출 시에도 서버에서 권한을 다시 확인하는 방식으로 결정했다.

기획팀은 운영팀 요청 중 “통계 다운로드 권한 분리”도 중요하다고 했지만, 이번 배포에 환불 승인 권한과 통계 다운로드 권한을 모두 넣으면 테스트 범위가 커진다고 판단했다. 따라서 통계 다운로드 권한 분리는 다음 배포 후보로 남기고, 이번에는 환불 승인 권한 분리에 집중한다.

QA 담당자는 권한 기능은 눈에 보이는 UI보다 예외 케이스 테스트가 더 중요하다고 했다. 예를 들어 권한이 없는 사용자가 **API URL**을 직접 호출하는 경우, 다른 관리자의 토큰으로 요청하는 경우, 권한 변경 직후 기존 세션이 유지되는 경우 등을 확인해야 한다. 권한 변경 후 즉시 세션을 만료할지, 다음 요청부터 새 권한을 적용할지도 결정이 필요하다. 이 부분은 백엔드팀에서 구현 방식을 검토한 뒤 다시 공유하기로 했다.

3. 결정사항

이번 1차 개선에서는 환불 승인 권한만 별도 분리한다.
통계 다운로드 권한 분리는 다음 배포 후보로 보류한다.

권한이 없는 메뉴는 프론트에서 숨긴다.

API 요청 시 백엔드에서 권한을 반드시 재검증한다.

권한 없는 사용자가 환불 승인 **API**를 호출하면 **403** 응답을 반환한다.

권한 변경 후 세션 처리 방식은 백엔드 검토 후 확정한다.

4. 액션 아이템

박도현 - 환불 승인 권한 필드와 **DB** 반영 방식 설계 - 오늘 오후 6시

박도현 - 환불 승인 **API** 권한 검증 로직 추가 - 내일 오전

최유리 - 권한 없는 메뉴 숨김 처리 **UI** 적용 - 내일 오후

김태훈 - 권한 없는 **API** 직접 호출 테스트 기준 정리 - 내일 오전

정민아 - 권한별 테스트 시나리오 작성 - 내일 오후

이수진 - 운영팀에 통계 다운로드 권한 분리 일정 안내 - 마감일 미정

미정 - 권한 변경 후 기존 세션 처리 방식 최종 결정 - 다음 회의

5. 리스크 및 주의사항

프론트에서 메뉴를 숨기는 것만으로는 보안 통제가 충분하지 않다.

기존 **API**마다 권한 체크 방식이 달라 일부 **API**에서 누락이 발생할 수 있다.

권한 변경 후 기존 세션이 계속 유효하면 변경 전 권한으로 작업이 가능할 수 있다.

환불 승인 기능이 막히면 운영 업무가 지연될 수 있으므로 배포 전 권한별 테스트가 필요하다.